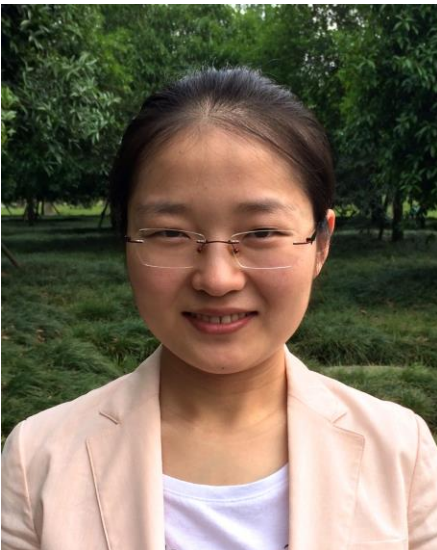


COMPSCI5063

CyberSecurity

Fundamentals

(CSF)



Dr Emma Li
Senior Lecturer
School of Computing Science

HOUSE KEEPING AND GROUND RULES

Course Aims

- Course Spec:
[https://www.gla.ac.uk/coursecatalogue/course/?code=C
OMPSCI5063](https://www.gla.ac.uk/coursecatalogue/course/?code=COMPSCI5063)
- To provide an overview of Cyber Security
- Explain a number of different security protocols;
- Evaluate a system in terms of potential vulnerabilities and recommend the most appropriate security solutions
- Explain cyber security fundamentals concepts - Ethical hacking, Digital Forensics and Penetration testing (or pen testing);
- Summarise the key vulnerabilities, threats, and attacks and explain approaches to mitigate these issues;
- Implement an aspect of cyber security;

Communications

- Use **Moodle Discussion Forum** for general questions
 - Use **Moodle Coursework Questions Forum** for questions about coursework
 - Help each other through “peer support”
 - Use **Lab Assistants** about coding/software during labs
 - **Do not** DM or email the course coordinators or the lab assistants
 - Unless**
 - You have a problem that will affect your performance
- Please find our Office hours on Moodle page:
Online and In-person meetings

How To Do Well

- Attend all the classes and do the small exercises and quizzes.
 - ✓ Learn as you go
 - ✓ It is too difficult to try and learn the course just before the exam.
- Don't spent too much time on the assessed exercises for this and other courses trying to get an A.
 - ✓ Most marks are in the exam.
 - ✓ You do well in the exam by learning the course as you go.

Code of conduct

- Please raise your hands if you would like to ask a question
- We will all treat each other with respect and dignity. Bullying and harassment will not be tolerated.

Schedules

- Lectures

Weeks 1-10 (Note: **Week 2 is online via Zoom**)

- Tutorials

Weeks 2-5 and Week 9-10

- Lab Sessions

Weeks 6-8

*Please check Moodle page for details.

Assessments – COMPSCI5063

Deadlines

- In class Quizzes (W2 – W5)

The quiz **will not** count into the course mark.

Each quiz is open for 2 days.

- Lab report (20%)

Due at 4pm 12th March
(Thursday)

- Written Assignment (20%)

Due at 4pm 25th
February (Wednesday)

- Individual Exam (60%)

April/May

Plagiarism and Cheating

- If you copy someone else's code or report without contribution and present it as your own work, this constitutes plagiarism
- If you cheat on the lab report, your individual coursework mark will be set to 0 (i.e. you will lose 40% (COMPSCI5063) of your course mark)



INTRO TO CYBER SECURITY

Name some cyber attacks

Weak Passwords

Phishing attacks

Trade secrets and insider data theft

Ransomware

Malware Attacks

Sensitive data leaks and breaches

Insider Threats

Question?

How many cyber attacks are there a day?

Please Join at slido.com with #

High-level plan for secure system

Systematic thought is required for successful defense

- Goal: Protect assets
 - only legible entity/authorized users could receive a file or use the system
- Aspects of Cyber Security (asset protection)
 - ✓ Confidentiality, Integrity, Availability, Authenticity, Accountability, Non-repudiation
- Threat model: assumptions about what the attacker can do
 - ✓ e.g., can guess the password, cannot physically steal our server

High-level plan for secure system

Systematic thought is required for successful defense

- Policy: Some plan (rules) that will get your system to achieve the goal
 - ✓ e.g., set permissions on a file so it's only readable by Alice
 - ✓ Policy must include human components (e.g., do not share passwords)
- Mechanism: Software/hardware that your system uses to enforces policy
 - ✓ user accounts, passwords, encryption
- Often layered: mechanism of one layer is policy of next level down

Why need Cyber Security?

➤ To protect

❖ Assets

- Assets are things that need protection and are usually digital, such as files and digital money

❖ Some assets, such as keys and passwords, are important for cyber security but are not stored as files.

➤ Aspects of Cyber Security (asset protection):

- ✓ **Confidentiality, Integrity, Availability, Authenticity, Accountability, Non-repudiation**

Confidentiality

- The protection of information in the system so that an **unauthorized person cannot access it**
- This implies an access control mechanism.
 - Users must be identified.
 - Users are then authenticated.
 - Users are then authorised to access various assets.
The access can be controlled, for example, with read, write and execute permissions.

Confidentiality

- **Privacy** is the confidentiality of personal information.
- Examples
 - Using a password to control access.
 - Encrypting files

Integrity

- Ensure nothing is lost or deleted.
 - Either accidentally or deliberately.
- Make sure nothing is changed.
- Examples.
 - Use a message digest to detect if a file has been changed.
 - Use a public key certificate for network communications.

Availability

- Have capacity to meet demands.
- Resources are allocated fairly.
- Fault tolerance and recovery from failure.
- Examples
 - Protect against denial of service attacks.

Authenticity

- The property of being **genuine** and being able to **be verified and trusted**; confidence in the validity of a transmission, a message, or message originator.
- It **validates** the source or origin of data and other file transfers through proof of identity
 - This ensures that the message (email, payment transaction, digital file, etc.) was not corrupted or intercepted during transmission

Accountability

- Accountability
 - a crucial element of Building Integrity (BI) initiatives and one of the key principles of Good Governance. A responsible, responsive, and democratic security sector cannot be conceived without accountable personnel, institutions, and procedures.
 - an essential part of an information security plan
 - Pointed towards **who is responsible** for each cyber role in an organization

Non- repudiation

- Non-repudiation
 - The author / owner of a document cannot say it was not them.
 - Assurance that the sender of information is provided with proof of delivery and the recipient is provided with proof of the sender's identity, so neither can later deny having processed the information.
 - Non-repudiation **provides evidence of data's origin, authenticity, and integrity**
 - **Digital file is properly tracked and users' action are logged**

- Cyber security techniques should be designed to ensure these 6 aspects.

Case study

- What aspects of security does Gmail have?

Confidentiality

Availability

Integrity

Authenticity

Accountability

Non-repudiation

- Can you give other examples?

Threats

- What are we protecting assets from? Threats
- Different types of asset security are subjects to different threats.
 - A threat against confidentiality will be different from a threat against availability.
- When protecting an asset, we need to consider all possible threats.
- There are many different techniques to make sure we have considered all threats.
 - Standard lists of threats.
 - Standard techniques for dealing with them.

Vulnerabilities

- Different ways of protecting assets lead to different vulnerabilities.
- We can check the security of a system in two different ways.
 - From the viewpoint of an attacker. What are the attackers' goals? How can they achieve them?
 - From the viewpoint of the defender. What are the system's vulnerabilities?
- All the vulnerabilities collected together are called the **attack surface**.
 - As a defender, we want to reduce the attack surface.

Protection and Risk

- Protecting our assets from threats leads to a discussion of risks.
 - **Protection has a cost.**
 - The value of an **asset** might be less than the **cost** of protecting it.
 - Some forms of protection may be cheaper than others.
- Risks involve the probability of something happening, together with the effect of the attack succeeding.

Technical Solutions are Essential

- **Unbreakable encryption** to keep secrets and ensure data is not changed.
 - The algorithm can't be broken without the key.
 - Keys must be kept secret.
- **Digital signatures** to allow legally enforceable contracts.
 - So that signatures can't be forged.
- **Secure message digests** to provide document fingerprints without revealing the document content.
 - So that two different documents can't have the same message digest.
- **Secure protocols** to make sure the basic building blocks of encryption signatures and message digests are used correctly.
 - So that it is not possible to bypass the use of a key.

... but Not Enough

- People!
- Users may not comply with security policies.
- Organizations may develop policies that users find very difficult to use.
- Developers may not adhere to security guidelines when building systems.
- Regulatory bodies may not provide appropriate policies and rules and then may not enforce them.
- Need to consider socio-technical systems.
 - Consider people as well as the technical aspects of any system.

Questions

1. Explain, with examples, how a system that uses all the best encryption techniques can still be insecure.
2. Explain , with examples, the terms Confidentiality, Integrity and Availability (CIA).
3. Explain with examples how security problems can arise in hardware, software, networks, personnel, site and organization.
 - What CIA aspects are affected by each of your examples
4. What is Security Engineering and how is it similar to / different from Software Engineering?

Yeah, of course. I was actually hosting a panel at the Wealth Management Summit the other day, another FT Live event, and there was a panel — actually, I think the next host, Martin Arnold, was hosting it. But there was this guy who was a former cyber criminal, turned kind of government adviser now. And he showed this video that was posted on the dark web, and it was a live deepfake video of . . . There was this lady who was talking to what she thought was a retired Asian dentist, but in real time, you could see behind this dentist was a west African criminal gang, and he was talking and it was going live in real time through the voice of this Asian guy. And this lady was completely fooled by it. Apparently she lost about \$150,000, and the scary thing was, this wasn't just an example of it, this was an ad on the dark web for criminal gangs to go and purchase a monthly subscription to this software.

So the point is, now that this stuff is out there. In the past, you had to be a digital wizard or a tech guru to do it. Now, you can just buy it off the shelf and run it from your phone. So I think the scams is maybe the same as they've always been — romance scams, or you know, phishing scams or whatever. But the tech advances have been staggering, which mean that, you know, suddenly anyone can get involved and I don't think the penalties are that great. So, you know, it's just getting scarier and scarier.

- What cybersecurity attacks are mentioned in the conversation?
- What cybersecurity lessons can be learned from this?

Week 2 Lecture

- Week 2 Lecture will **be online By Philip Zhao.**
-
- **Zoom link** will be sent via **Moodle Course announcement.**

Knowledge Survey

- Please vote at [Slido.com](https://www.slido.com) with the code #
 - Do you have experience of using objectiveoriented Programming languages, e.g., Java, Python, C++?
 - Do you know seven-layer OSI model of computer networking?